

Implementa Políticas de Seguridad DLP a dispositivos de almacenamiento externo

Fecha: 10 de Junio de 2026

Elaborado por: Bryan Enrique Salazar Luna

Empresa: TechCorp Solutions

1.INTRODUCCION

La Prevención de Pérdida de Datos, conocida como DLP por sus siglas en inglés Data Loss Prevention, comprende el conjunto de políticas, procedimientos y controles técnicos destinados a identificar, monitorear y proteger información confidencial dentro de una organización.

El objetivo principal de una política DLP es evitar que datos sensibles sean divulgados, copiados, enviados, descargados o almacenados por usuarios no autorizados. Esta protección debe aplicarse tanto en sistemas locales como en servicios de almacenamiento y colaboración en la nube, estaciones de trabajo, correo electrónico y dispositivos extraíbles.

Este informe establece una política de seguridad orientada a reducir el riesgo de pérdida de información mediante la clasificación de datos, la aplicación del Principio del Menor Privilegio, el monitoreo de actividades, la auditoría de accesos, el uso de tecnologías de cifrado y DLP, y la restricción del uso de dispositivos USB como medida preventiva frente a la exfiltración de datos.

2.CLASIFICACION DE DATOS

Para aplicar controles adecuados, la organización clasificará la información según su nivel de sensibilidad, impacto potencial y necesidad de acceso. La clasificación de datos permite definir permisos, controles de seguridad y mecanismos de monitoreo proporcionales al riesgo.

- **Datos Públicos:** información que puede ser compartida sin afectar la seguridad, reputación o cumplimiento de la organización. Incluye comunicados oficiales, material de marketing, información publicada en la web corporativa y documentación autorizada para difusión externa.

- **Datos Internos:** información de uso exclusivo dentro de la organización. Incluye procedimientos internos, manuales operativos, reportes administrativos, documentos de trabajo y comunicaciones internas que no deben ser divulgadas públicamente.

- **Datos Sensibles:** información confidencial cuyo acceso, modificación o divulgación no autorizada puede generar daños legales, financieros, operativos o reputacionales. Incluye contratos, datos personales, información financiera, credenciales, registros de clientes, documentación legal, nóminas y propiedad intelectual.

Toda información generada, almacenada o compartida por la organización deberá clasificarse antes de ser procesada. Los datos sensibles deberán estar sujetos a controles reforzados, como cifrado, autorización formal, monitoreo continuo, restricciones de descarga y limitación del uso de dispositivos removibles.

3.ACCESO Y CONTROL

El acceso a la información se gestionará bajo el Principio del Menor Privilegio. Esto significa que cada usuario, proceso o sistema recibirá únicamente los permisos estrictamente necesarios para cumplir sus funciones laborales, evitando accesos amplios o innecesarios.

- **Acceso restringido:** los empleados solo podrán acceder a los archivos, carpetas, sistemas o repositorios necesarios para sus tareas asignadas.

- **Permisos por rol:** los accesos se asignarán mediante roles o grupos de seguridad definidos por área, función y nivel de responsabilidad.

- **Permisos de edición limitados:** solo los responsables directos de la información podrán modificar documentos sensibles. El resto de usuarios tendrá permisos de solo lectura cuando sea necesario.

- **Acceso temporal:** cuando un usuario requiera acceso temporal a información sensible, este deberá estar justificado, aprobado y revocado al finalizar la tarea o proyecto.

- **Prohibición de accesos generales:** no se permitirá el uso de permisos amplios como “todos los usuarios”, “cualquier persona con el enlace” o grupos genéricos para datos internos o sensibles.

3.1 Flujo de Revisión de Permisos

La revisión de permisos se realizará de forma periódica y documentada para garantizar que solo el personal autorizado conserve acceso a información sensible.

- El usuario solicita acceso indicando el recurso requerido, el motivo y el tiempo estimado de uso.

- El jefe de área valida que la solicitud sea necesaria para las funciones del usuario.

- El propietario del dato aprueba o rechaza el acceso según la clasificación de la información.
- El administrador de TI aplica el permiso correspondiente en el sistema, carpeta, aplicación o repositorio.
- El responsable de seguridad registra la autorización y verifica que el permiso respete el menor privilegio.
- Los permisos serán revisados trimestralmente o cuando exista cambio de puesto, baja de personal, cierre de proyecto o incidente de seguridad.

3.2 Roles Responsables

- Usuario final: utiliza la información únicamente para actividades autorizadas y reporta accesos indebidos o incidentes.
- Jefe de área: justifica la necesidad de acceso y valida los permisos requeridos por su equipo.
- Propietario del dato: decide quién puede acceder, modificar, descargar o compartir información sensible.
- Administrador de TI: configura técnicamente los permisos, grupos, políticas y restricciones.
- Responsable de Seguridad: supervisa el cumplimiento de la política, revisa alertas, realiza auditorías y coordina acciones correctivas.

4.MONITOREIO Y AUDITORIA

Se implementará una política de monitoreo y auditoría orientada a detectar accesos indebidos, uso inusual de datos sensibles, intentos de exfiltración y cambios no autorizados en permisos o configuraciones.

- Registro de actividades: se registrará quién accede a datos sensibles, desde qué equipo, cuándo lo hace y qué acciones realiza, incluyendo lectura, edición, descarga, copia, eliminación o compartición.
- Alertas de seguridad: se generarán alertas cuando se detecten acciones como envío externo de información sensible, descarga masiva de archivos, conexión de dispositivos USB, intento de copia a medios removibles o modificación inusual de permisos.
- Auditorías periódicas: se realizarán auditorías trimestrales sobre permisos, accesos a datos sensibles, eventos de dispositivos removibles y cumplimiento de la política DLP.
- Conservación de registros: los logs relacionados con datos sensibles deberán conservarse durante un periodo mínimo definido por la organización, recomendado entre 6 y 12 meses.

4.1 Herramientas de Monitoreo y Auditoría

Para ejecutar las actividades de monitoreo y auditoría, la organización podrá utilizar herramientas específicas según su infraestructura tecnológica:

- Soluciones SIEM: herramientas como Wazuh, Splunk o Microsoft Sentinel permitirán centralizar eventos, correlacionar actividad sospechosa y generar alertas de seguridad.
- Soluciones DLP: plataformas como Microsoft Purview DLP, Google Workspace DLP o Forcepoint DLP permitirán identificar datos sensibles, aplicar reglas de bloqueo y controlar el intercambio de información.
- Herramientas EDR o protección de endpoints: soluciones como Microsoft Defender for Endpoint permitirán detectar actividad anómala en estaciones de trabajo y controlar el uso de dispositivos removibles.
- Visor de eventos de Windows: se utilizará para revisar eventos locales relacionados con políticas de grupo, acceso a dispositivos, errores de autorización y actividad del sistema.
- Consolas administrativas en la nube: en servicios como Google Workspace o Microsoft 365, se revisarán logs de acceso, descargas, compartición externa y cambios de permisos.

5.PREVENCIÓN DE FILTRACIONES

La organización aplicará controles preventivos para evitar que los datos sensibles salgan del entorno autorizado. Estos controles deberán aplicarse tanto a usuarios internos como a terceros con acceso autorizado.

- Cifrado de datos: la información sensible deberá protegerse mediante cifrado en reposo y en tránsito, reduciendo el impacto en caso de acceso no autorizado.
- Bloqueo de compartición externa: no se permitirá compartir documentos sensibles con usuarios externos salvo autorización formal del propietario del dato.
- Etiquetado de información: los documentos sensibles deberán identificarse mediante etiquetas como “Confidencial”, “Uso interno” o “Datos sensibles”.
- Reglas DLP: las herramientas DLP deberán detectar información como datos personales, documentos financieros, credenciales o contratos, y bloquear su envío, copia o descarga no autorizada.
- Control de dispositivos USB: el uso de dispositivos de almacenamiento removable deberá restringirse para impedir la copia o extracción no autorizada de información.
- Autenticación multifactor: los accesos a sistemas que contengan datos internos o sensibles deberán protegerse mediante MFA cuando sea técnicamente posible.
- Revisión de incidentes: cualquier intento de filtración, acceso indebido o copia no autorizada deberá ser registrado, investigado y tratado conforme al procedimiento de respuesta a incidentes.

6. EDUCACIÓN Y CONCIENTIZACIÓN

La efectividad de una política DLP depende también del comportamiento del personal. Por ello, la organización capacitará a los empleados sobre el uso correcto de la información, los riesgos asociados a la exposición de datos y las consecuencias del incumplimiento de las políticas.

- Capacitación inicial: todo nuevo empleado recibirá formación sobre clasificación de datos, menor privilegio, uso seguro de archivos y reporte de incidentes.
- Capacitaciones periódicas: se realizarán sesiones trimestrales para reforzar buenas prácticas, explicar cambios de política y presentar ejemplos de incidentes reales o simulados.
- Concientización sobre dispositivos USB: se explicarán los riesgos de utilizar dispositivos removibles, incluyendo malware, robo de información y copia no autorizada de archivos.
- Evaluaciones de comprensión: después de cada capacitación, el personal deberá completar una evaluación básica para verificar que comprende sus responsabilidades.
- Canales de reporte: los empleados deberán conocer los canales oficiales para reportar pérdida de dispositivos, accesos indebidos, correos sospechosos o exposición accidental de información.

7. CONCLUSIÓN

La implementación de políticas DLP permite reducir el riesgo de pérdida, exposición o uso indebido de información confidencial dentro de la organización. Para que estas políticas sean efectivas, es necesario clasificar los datos, limitar los accesos, monitorear la actividad, auditar permisos y capacitar al personal de forma continua.

La restricción del uso de dispositivos USB refuerza la protección de datos sensibles al impedir que usuarios no autorizados copien o extraigan información mediante medios removibles. Esta medida, combinada con cifrado, herramientas DLP, monitoreo SIEM y aplicación del Principio del Menor Privilegio, fortalece la postura de seguridad de la organización.

Con estas políticas, la organización establece un marco de control claro para proteger datos públicos, internos y sensibles, asegurando que solo el personal autorizado acceda a la información necesaria para realizar sus funciones.